

Criptografía

Criptografía

Transformación matemática de
datos

Funciones

Autenticación de host cliente: El host cliente es verdaderamente el que espera el host servidor al establecer una conexión.

Autenticación de host servidor: El host servidor es verdaderamente el que el host cliente espera al establecer una conexión.

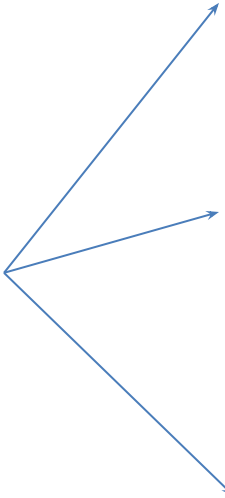
Autenticación de usuario: El usuario que inicia una sesión es verdaderamente quien dice ser.

Autenticación de mensajes o documentos: Asegura que un mensaje a sido escrito o producido por su verdadero autor (firma digital).

Integridad: Asegura que nada ni nadie modifica una mensaje en su recorrido.

Confidencialidad: Asegura que solo el destinatario pueda leer un mensaje.

Tipos de
criptografía



```
graph LR; A[Tipos de criptografía] --> B[Encriptación en un sentido (HASH)]; A --> C[Encriptación en dos sentidos con clave simétrica]; A --> D[Encriptación en dos sentidos con clave asimétrica];
```

Encriptación en un sentido (HASH): Todo mensaje encriptado no puede ser descryptado nunca más.

Encriptación en dos sentidos con clave simétrica:
Todo mensaje encriptado con una clave puede ser descryptado con la misma clave.

Encriptación en dos sentidos con clave asimétrica:
Todo mensaje encriptado con una clave, puede ser descryptado con otra. Una de estas claves debe ser pública y la otra privada.

- **Para lograr la funcionalidad descrita en el punto anterior, se recurre a uno o varios tipos combinados de criptografía.**
- **Algunas técnicas criptográficas hacen uso de los tres tipos de criptografía en forma conjunta.**

Encriptación unidireccional

Hash:

Es una transformación de datos de cualquier tamaño en una palabra de longitud fija. Esta transformación es irreversible. El producto generado se llama hash y el algoritmo que la realiza se denomina función hash.

Implementaciones de hash:

MD5 ☐ Produce un número de 128 bits (16 octetos). Cada octeto se puede expresar como un «par hexadecimal» o sea que la palabra del hash tiene 32 dígitos hexadecimales de longitud).

SHA1 ☐ Produce un número de 160 bits (20 octetos o pares hexa o 40 dígitos hexadecimales de longitud)

SHA256 ☐ Produce un número de 256 bits (32 octetos o pares hexa o 64 dígitos hexadecimales de long.)

Ejemplos:

- Un documento puede ser enviado por un medio de comunicación y su hash calculado por otro medio de comunicación diferente. En el destino se calcula nuevamente el hash del documento recibido y se lo compara con el hash transferido por el otro medio. Si coinciden queda garantizada la autenticidad del documento.
- Una contraseña de usuario que inicia una sesión con una aplicación es transformada en su hash al llegar. Este hash es comparado con otro almacenado en disco del lado del servicio. Si la contraseña encriptada coincide con el hash almacenado se estaría autenticando al mismo.

Criptografía bidireccional simétrica

Se basa en la encriptación de un mensaje con una clave que también sirve para su des-encriptación. Esta clave es única y debe ser conocida de antemano y mantenida en secreto tanto por el emisor como por el receptor. Es el procedimiento más eficiente para la encriptación de grandes cantidades de datos.

Implementación:

DES (Data encryption Standard) (clave o llave de 56 bits) ya fuera de uso
3DES(clave o llave de 158 bits) ya casi en desuso.

AES (Advanced Encryption standard) (clave o llave de: 128, 192 y 256 bits)

En todas las implementaciones se busca obtener la mayor velocidad posible.

Actualmente AES es la más usada. Cuanto mayor es el tamaño de la clave más lentos son los procesos de encriptación y des-encriptación

Ejemplo:

Una transferencia de datos utilizando este tipo de encriptación garantiza la autenticidad de los mismos además de su integridad pero obliga a conocer la clave secreta de ambos lados. Dicha clave debe ser transferida por otro medio o en otro momento.

En php estan las funciones mcrypt que permiten encriptar y desenscriptar.

Criptografía bidireccional asimétrica

Se basa en la encriptación de un mensaje con una clave y la des-encriptación con otra diferente. Una de dichas claves (cualquiera de ellas debe ser privada y la otra pública).

Implementaciones:

RSA (normalmente se configuran claves de 1024 bits o 2048 como por ejemplo las claves RSA usadas por GlobalSign en sus protocolos de cifrado ssl)

Ejemplos:

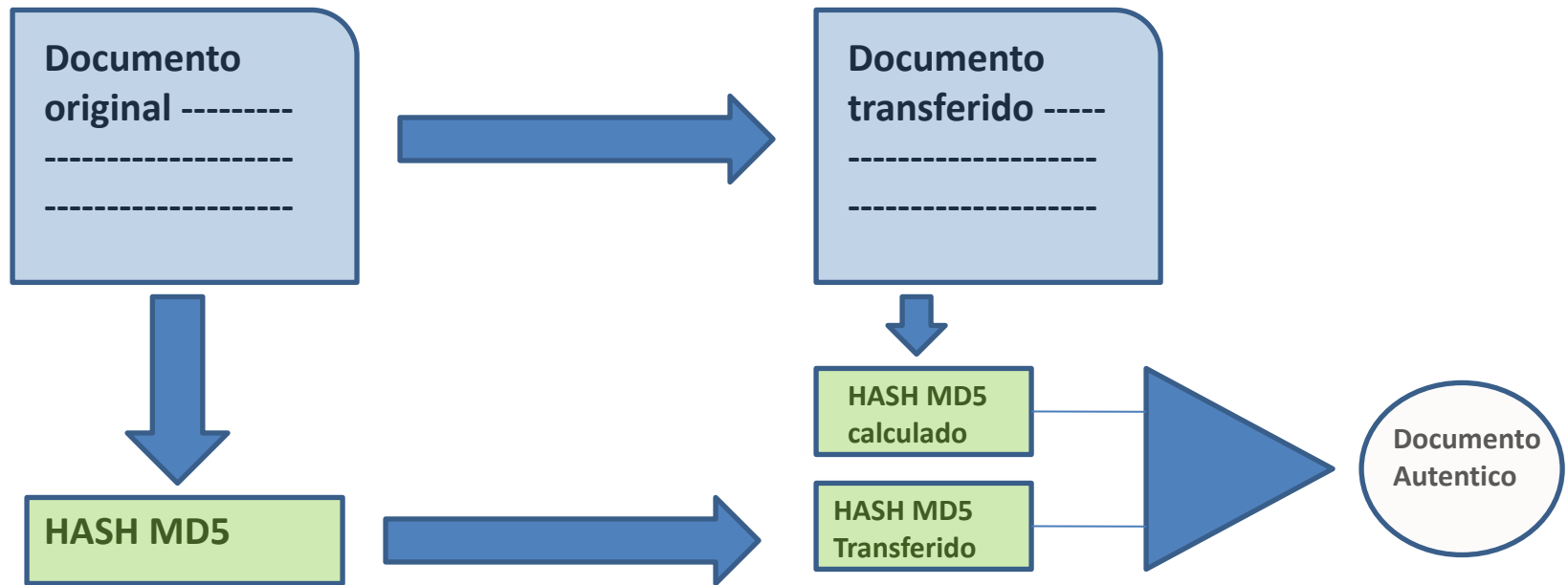
- Si se encripta con la clave pública del receptor para que éste a su vez descifre con su privada se logra confidencialidad.
- Si se encripta con la clave privada del emisor para que el receptor descifre con la pública del primero se logra autenticidad.
- Si se encripta doblemente con la privada del emisor y la pública del receptor para que este a su vez descifre con la pública del primero y luego con su privada, se estaría logrando confidencialidad para el emisor y autenticidad para el receptor.

Aclaración:

Estos algoritmos son extremadamente complejos y lentos y por lo tanto no se pueden aplicar para transferir grandes cantidades de datos. Si son ampliamente usados para la transferencia de claves simétricas y de hashes.

Firma digital

OPCION 1 Hash utilizado como firma:



En el medio cualquiera puede modificar el documento y crear un nuevo hash MD5 . La solución sería transferir el hash por un medio distinto al que se usó para transferir el documento.

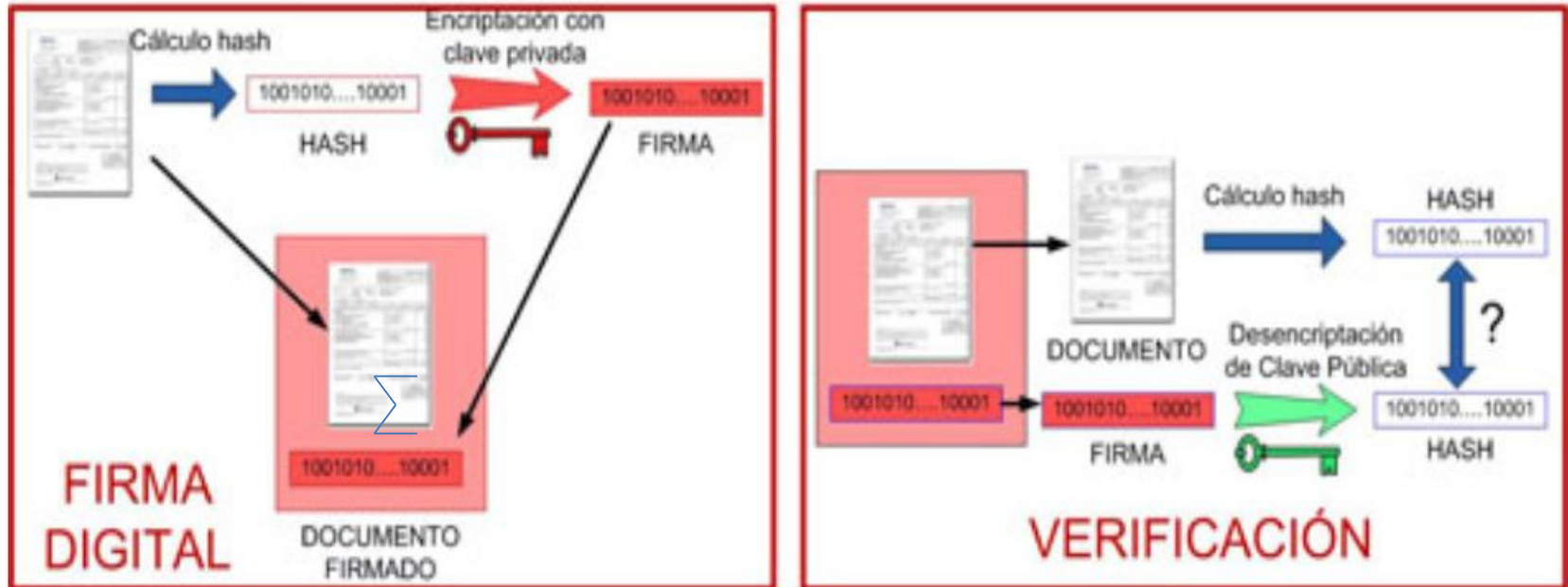
OPCION 2 Documento totalmente encriptado con clave RSA privada del emisor:

Garantiza la autenticidad del documento pero genera un producto encriptado de gran tamaño y requiere de mucho tiempo de procesamiento para desencriptar.

OPCION 3 (usada) Hash encriptado con clave RSA privada del emisor:

Usando esta firma se garantiza autenticidad del documento. La firma es el producto encriptado asimétricamente con privada del origen del hash md5 del documento (no de todo el documento).

Resumiendo:



Cualquier software de firma electrónica tiene previamente definidos y disponibles la Clave privada (.key) y la clave pública firmada por CA (.cert)

Si en el medio alguien extrae el documento y lo modifica, jamás va a poder generar una firma compatible con la firma original ya que no dispone de la key privada original.

La firma digital remota (sin token) es un certificado que sirve únicamente para firmar digitalmente archivos en formato PDF a través del Firmador.

Tiene validez jurídica.

Garantiza autenticidad e integridad del documento.

Si usted solicitó un certificado de firma digital remota dentro de la plataforma (PFDR) en una Autoridad certificante del Ministerio de Modernización (AC-Modernización), sólo podrá gestionar el cambio de clave a través de un OTP (one time password) en la misma Autoridad de Registro que le aprobó su certificado.

Una vez finalizado el trámite, se puede firmar digitalmente a través del firmador de nación:

www.firmar.gov.ar/firmador/#/

Hay que ingresar con CUIL y contraseña PIN.

Ingresar el código OTP sacado de la aplicación instalada en el móvil y pulsar Acceder

Luego se sube el documento

Luego ingresar nuevamente el PIN o contraseña de firma

Luego pulsar firmar

Luego descargar documento firmado.

El mismo lector de PDF dentro de sus opciones tiene la posibilidad de validar la firma.

SSL/TLS

Secure socket layer es una capa de seguridad que protege a cualquier aplicación que corra sobre ella garantizando:

- 1) Autenticación de servidor
- 2) Autenticación de cliente
- 3) Negociación de una clave simétrica de encriptación rápida
- 4) Encriptación bidireccional de todos los datos transferidos desde y hacia el servidor.

Certificados ssl de un server o de un dominio

El certificado ssl es la clave pública de un servidor o de un dominio firmada por una autoridad certificante como digicert o globalsign.

Con esto quien quiera establecer un requerimiento https con dicho server podrá confiar autenticando a dicho servidor y encriptando toda la información transferida Sobre un canal seguro. La clave de encriptación es simétrica y se negocia luego del protocolo de inicio ssl.

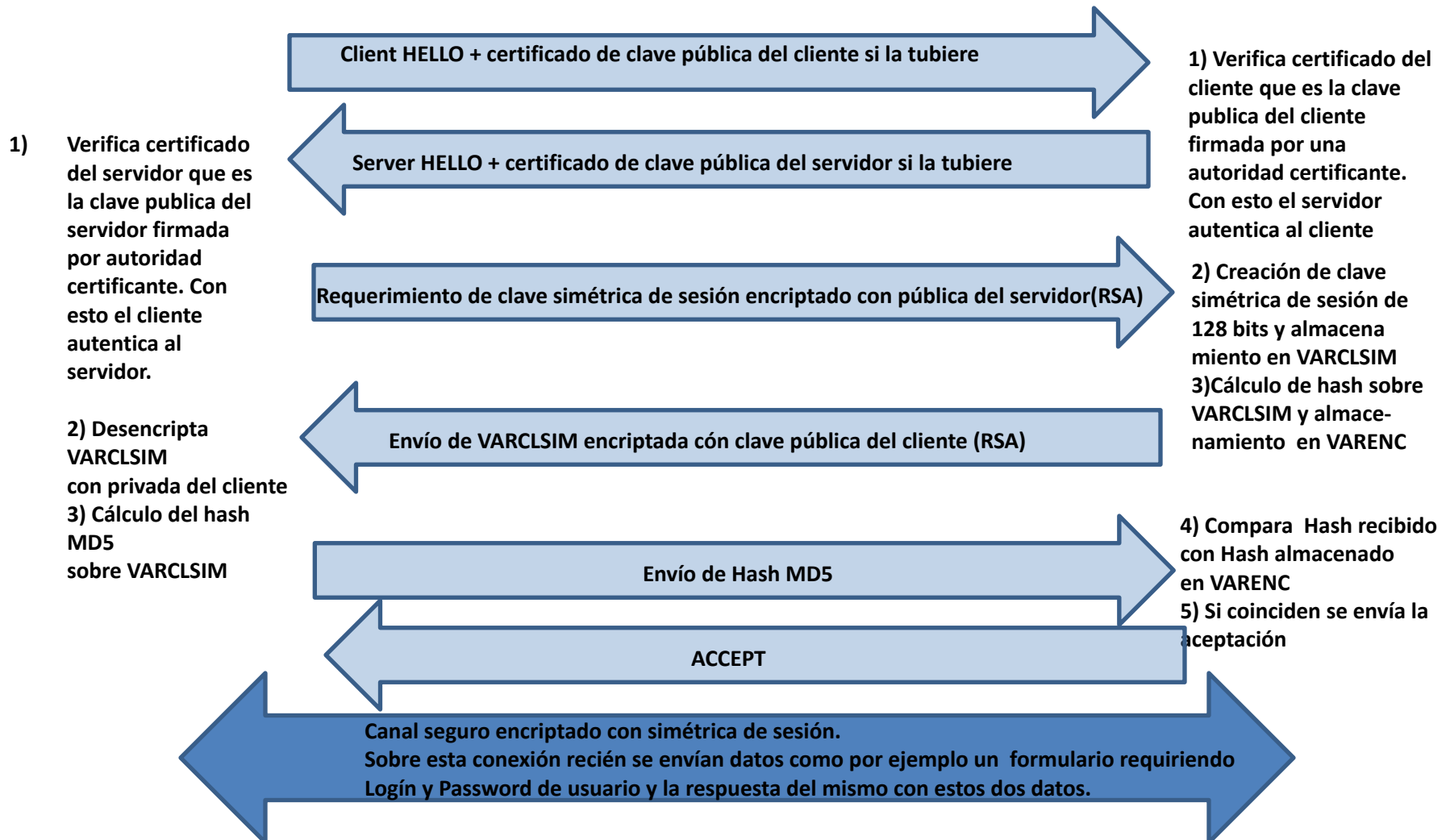
SSL

Layer para crear un canal seguro encriptado

Cliente

Servidor

Conexión UDP luego del saludo de tres vías



Certificados ssl

.key

Es el archivo que contiene la clave privada

.csr

Es el archivo que contiene el pedido(req) de certificación para enviar a la autoridad certificante. Esta devolverá el archivo firmado .crt por la autoridad certificante.

.crt

Es el archivo que contiene el certificado firmado por una autoridad certificante o el certificado autofirmado si tu mismo lo generaste. En este último caso tendrás que repartir este certificado autofirmado a tus usuarios clientes para que estos lo importen en su navegador. Para importar el crt hay que ir a la opción de Chrome de configuración ☐ Mostrar configuración avanzada ☐ https/ssl ☐ Ficha de entidades de confianza ☐ Importar.

Que es una CA?

Autoridad certificante es una organización que registra y valida las identidades de las entidades que intercambian información en una red.

Estas entidades poseen claves públicas certificadas o firmadas digitalmente por dicha autoridad certificante.

Procedimiento para la obtención del certificado:

- 1) En el servidor web se debe configurar un nuevo host virtual (ej: `wwwhostseguro.miescuela.edu.ar`) que atienda en el port 443 y que admita requerimientos ssl.
 - 2) Hay que generar con openssl la clave privada para el dominio nuevo (`wwwhostseguro.miescuela.edu.ar`).
 - 3) En el anterior proceso también se genera un archivo `.csr` que es el Requerimiento de certificado que será luego firmado por la autoridad certificante.
 - 4) La autoridad certificante que podemos ser nosotros mismos generamos a partir del csr un `.crt` que no es ni mas ni menos que una clave publica para el dominio firmada por la CA (autoridad certificante).
Esto es el hash calculado sobre la publica mencionada encriptado con clave privada de la CA.
 - 5) Este `.crt` si no somos una entidad certificante reconocida y dada de alta en todos los navegadores, debemos instalarla en el navegador que quiere acceder como cliente a nuestro host virtual.
- Las autoridades certificantes reconocidas tienen sus claves publicas disponibles en todos los navegadores.

Procedimientos para windows:

1. Bajar de internet openssl para Windows
2. Observar que al instalar el ejecutable queda en C:\Program Files\GnuWin32\bin
3. Entrar como administrador en la línea de comando de Windows
4. Ejecutar:
openssl genrsa -out privada 2048
Esto genera en la carpeta el archivo privada que contiene la clave privada
5. Ejecutar:
openssl req -new -key privada -subj "/C=AR/O=xxxsa/CN=Gustavo Wittbecker/serialNumber=CUIT 30629646708" -out pedido
Esto genera un archivo pedido que se lo puede renombrar como pedido .csr
6. Entrar en ARCA en administración de certificados digitales y subir este archivo pedido.csr para recibir el certificado validado nombre.crt
7. copiar este archivo al server del ERP \\SERVER\CertificadosAFIP
8. En los puestos de trabajo hay que ir a administración de comprobantes electrónicos y apuntar a este nuevo certificado validado por la autoridad certificante.